

개미집 인프라 구축 보고서

인프라 보안 12기 가디언즈

2026. 08.

1 개요

구현 실제 적용·테스트 완료 **설정확인** 기존 값·사실 확인(정책 아님) **설계** 설계만 완료, 미적용 **TBD** 팀 확인·실측 필요
해당없음 본 프로젝트 범위 아님

1.1. 수행 목적

TBD 팀 합의 문구 필요 (예시: 모의투자 웹서비스 "개미집"의 인프라를 직접 설계·구축하고, 실제 발견된 보안 취약점에 대한 조치 및 접근제어 정책을 수립·적용한다.)

1.2. 수행 일정

TBD 전체 기간을 사이클(1차/2차/3차)로 나눠 목표를 명시하는 방식 권장. 아래는 채워 넣을 표 구조입니다.

[표 2] 수행 일정

구분	역할	작업	기능상세	담당	수행 일정
1차 (기반환경)	공통	인프라 설계	TBD 6서버 구조 및 VPN 토폴로지 확정		
	FW	VPN 구축	구현 OPNsense WireGuard 서버/Peer 구성 완료		
	DB/WEB	OS·서비스 설치	구현 Ubuntu, nginx, PHP-FPM, MariaDB 구동 중		
2차 (서비스 구현)	WEB	서비스 기능 구현	구현 회원가입/로그인/매수 매도/실시간시세 등 전 기능 운영 중		
	DB	스키마/연동	구현 MariaDB 스키마 운영 중		
EST			개미집 인프라 구축 보고서 인프라 보안 12기 가디언즈		EST

구분	역할	작업	기능상세	담당	수행 일정
3차 (보안 강화)	FW	방화벽 정책 전환	설계 any→any 제거, 화이트리스트 룰 설계 완료.적용 보류		
	WEB/DB	취약점 조치	구현 CSRF-세션-브루트포스-SQLi-레이스컨디션 등 조치 완료		

1.3. 수행 인력 및 업무(R&R)

TBD 팀원별 담당 서버·세부 작업을 아래 형식으로 채워주세요.

[표 3] 수행 인력

영역	담당 서버	세부 작업 항목	담당
PM / 총괄	-	TBD 일정 관리, 문서 총괄, 발표 준비	
Front-End	웹서버	TBD UI/UX, 대시보드 위젯	
Back-End	웹서버	TBD 매수·매도·주문 로직, KIS/카카오 연동	
Security	웹서버/OPNsense	TBD CSRF-세션-WAF-방화벽 정책	
DB	DB서버	TBD 스키마 설계, 접근 권한, 백업	
SecOps/Monitoring	Graylog	TBD 로그 수집·관제	

1.4. Ground Rule

TBD 팀 합의 필요. 아래는 채워 넣을 항목 구조입니다(예시 항목).

1.4.1. 변경 관리(Change Management) 규칙

- TBD** 모든 방화벽/서버 설정 변경은 (팀장/전원) 승인 후 적용
- 변경 내역 기록 채널 지정 (예: 노션, 디스코드)
- 운영 서버 직접 실험 금지 — 테스트 → 검증 → 적용 순서 준수

1.4.2. 접근 통제 규칙 (Access Control)

- 구현** SSH 접속은 반드시 WireGuard VPN을 통해서만 허용
- TBD** root 직접 로그인 금지 여부, 개인별 계정 사용 여부
- 불필요한 포트 차단(Default Deny 유지) — **설계** 상태, 적용 보류

1.4.3. 역할 존중 규칙 (R&R 보호)

TBD 영역별 책임자 지정 (네트워크/WAF/DB/로그) 및 타 영역 변경 전 협의 원칙

1.4.4. 보안 사고 대응 규칙 (Incident Response)

- EST** 로그 발견 시 즉시 공유
- 로그 삭제 금지, 증적 보존

3. 원인 분석 후 재발 방지 문서화 — "누가 실수했는가"가 아니라 "어떤 구조가 문제였는가"를 본다

1.4.5. 코드 및 설정 관리 규칙

1. 설정 파일은 백업 후 수정 — **구현** 배포 시 `/var/backups/stock-app-quarantine/` 에 백업 관행 적용 중
2. API Key/비밀번호는 환경변수·설정파일로 분리 관리

1.5. WBS

TBD 전체 일정을 사이클/작업/담당자/기간 컬럼을 가진 간트 표로 별도 작성 권장 (예: 노션·엑셀 WBS를 캡처하여 삽입).

2

기업 및 서비스 현황

2.1. 기업 소개

[표 4] 기업 소개

구분	내용
서비스명	설정확인 개미집 (junwon.xyz)
서비스 형태	설정확인 PHP · MariaDB 기반 모의투자(가상 주식거래) 웹서비스

2.1.1. 기업 일반 현황

TBD

실제 회사가 아닌 팀 프로젝트인 경우 "가상 기업 개요" 형태로 대체할지 팀 논의 필요. 예시 서술 방식: 팀 소개 문구 + 미션/비전 1~2문단.

2.1.2. 서비스 소개

구현

카카오·구글 소셜 로그인(아이디·비밀번호 로그인 폐지), 실시간 시세·차트·호가, 지정가/시장가 매수·매도(장 시간 외 대기 후 자동체결), 관심종목, 거래내역, 증시뉴스(구글/네이버 API 연동, 원문 링크 제공), 대시보드 위젯(GridStack) 제공

TBD

실제 서비스 화면 스크린샷 삽입

2.1.3. 조직 및 인원현황

[표 5] 조직도

구분	인원
TBD	팀 조직도

2.2. 웹 서비스 설명

2.2.1. 웹 서비스 주요 기능

[표 6] 주요 기능

기능 분류	세부 기능	설명
계정	회원가입 / 로그인	카카오·구글 소셜 로그인(아이디·비밀번호 로그인 폐지, 2026-08-12부터). 네이버 로그인은 검토 후 미채택
	세션 관리	HttpOnly / SameSite=Lax / 조건부 Secure 쿠키
거래	매수 / 매도	지정가·시장가 주문, 체결/미체결(PENDING) 관리, 장 시간(09:00~15:30) 외에는 대기 후 다음 장 시작 시 자동 체결
	주문 취소·정정	cancel_order.php / modify_order.php
	레이스컨디션 방지	매도 시 보유수량 조회에 SELECT ... FOR UPDATE 적용
EST	실시간 시세·차트·호가	SSE 스트림(/stream) 개미집 인프라 구축 보고서 KIS Open API 연동 인프라 보안 12기 가디언즈
		EST

기능 분류	세부 기능	설명
	증시 뉴스	구글 뉴스 RSS(웹서버 cron) + 네이버 뉴스 검색 API(뉴스 연동서버 10.10.10.7)로 수집, 기사 원문 링크 클릭 이동 지원. 기존 KIS 뉴스 헤드라인 폴러는 원문 링크 미제공으로 중단
기타	관심종목 / 거래내역 / 대시보드 위젯	GridStack 기반 커스텀 대시보드

2.2.2. 예상 사용자 및 트래픽

[표 7] 예상 사용자 및 트래픽

구분	항목	수치
목표치	예상 가입자 수	TBD 팀 합의 필요
	동시접속자 목표(피크, 장 시작 9시 등)	TBD
현재 실측(참고)	PHP-FPM 동시 처리 한계	설정확인 pm.max_children = 5, pm.start_servers = 2 (튜닝 전 기본값)
	DB 최대 커넥션	설정확인 max_connections = 151 (기본값, 튜닝 전)

참고: 현재 설정 기준 동시접속 5,000명 규모(장 시작 시간대 집중)는 PHP-FPM 동시 처리 한계(5개)로 인해 처리 불가로 확인됨. 목표 트래픽 확정 시 역산하여 pm.max_children / innodb_buffer_pool_size 등 캐파를 재산정해야 함.

3

서버 및 네트워크 구성도

3.1. 서버 구성

3.1.1. 전체 서버 구성도(Underlay)

- 설정확인

기존에 작성한 서버 토폴로지 다이어그램 기반으로 삽입 가능. 개미집 프로젝트는 아래 6개 서버로 구성됨.
- 해당없음

크롤링 서버 / AI 서버 / 백업 서버 / OPNsense 이중화(2대) — 본 프로젝트 범위에 포함되지 않음

3.1.2. 서버별 상세

[표 9] 서버별 상세

할당	서버	역할	CPU	RAM	SSD	OS	소프트웨어
설정확인	웹서버 10.10.10.3	nginx + PHP-FPM 웹서비스	4코어	3.3GB	TBD	Ubuntu	nginx, PHP 8.5-FPM, ModSecurity
설정확인	DB서버 10.10.10.2	MariaDB	4코어	3.3GB	TBD	TBD	MariaDB (max_connections=151)
설정확인	OPNsense 게이트웨 이	방화벽 / VPN 게이 트웨이 (단일, 이 중화 없 음)	TBD	TBD	TBD	FreeBSD (OPNsense)	WireGuard
설정확인	카카오 로 그인 연동 서버 10.10.10.6 (장우영)	카카오 로 그인 연동 (티켓 발 급·검증)	TBD	TBD	TBD	TBD	TBD
구현	구글 로그 인 연동서 버 10.10.10.8 (함도율)	구글 로그 인 연동 (OAuth 토 큰교환·프 로필조회· 계정생성)	TBD	TBD	TBD	Ubuntu	PHP 8.5(CLI, 내장서버:8090), pdo_mysql/curl/mbstring, systemd(google-login-api.service) — 카카오 연동서버와 동일 패턴(웹 서버는 인증코드만 전달, 토큰교환 ·DB기록은 이 서버가 직접 수행)
구현	뉴스 연동 서버 10.10.10.7 (윤탁준)	네이버 뉴 스 검색 API 수집 (3분 주기)	TBD	TBD	TBD	Ubuntu	PHP 8.5(CLI), pdo_mysql/curl/mbstring/xml, systemd(market-news- naver.service)
설정확인	KIS(한국투 자증권) 연 동서버 10.10.10.4 (장원영)	시세 · 시 장데이터 수집	TBD	TBD	TBD	Ubuntu	Python, Redis, RabbitMQ, Spring Boot(8080), 한국투자증권 Open API 연동
EST	개미집 인프라 구축 보고서 인프라 보안 12기 가디언즈						EST

할당	서버	역할	CPU	RAM	SSD	OS	소프트웨어
구현	Graylog 서버 10.10.10.5 (장우영)	중앙 로그 수집	TBD	TBD	TBD	Ubuntu	Graylog 7.1, OpenSearch, MongoDB, Java 21, rsyslog input(:1514), Beats input(:5044)

크롤링 서버 / AI 서버 / 백업 서버 / OPNsense-2(이중화): 해당 없음. 증시뉴스 수집은 소스별로 분리됨 — 구글 뉴스(RSS)는 웹서버(10.10.10.3) 내 cron으로, 네이버 뉴스(API)는 별도 뉴스 연동서버(10.10.10.7)로 처리. 기존 KIS 뉴스 헤드라인 폴리는 원문 링크 미제 공 문제로 중단(비활성화)함.

3.2. 네트워크 구성

3.2.1. 네트워크 다이어그램(Overlay)

설정확인(부분) WireGuard VPN 메시(10.10.10.0/24) 기반 오버레이 구조 파악됨. 전체 서버 포함 재작성 필요.

3.2.2. 네트워크 구역별 설명

[표 12] 네트워크 구역

구역	IP 대역	용도	배치 서버
DMZ	TBD	외부 노출 서비스	웹서버(nginx)
내부망(VPN)	10.10.10.0/24	서버간 통신	DB, 카카오 연동, KIS 연동, Graylog
관리망	TBD	관리자 접근 전용	전체 서버 SSH

3.2.3. 네트워크 주요 보안 장비

[표 13] 네트워크 보안 장비

구분	주요 역할	작동 방식
OPNsense(방화벽)	구현 트래픽 필터링, VPN 게이트웨이	Stateful 방화벽, WireGuard 인터페이스 그룹 기준 규칙
ModSecurity(WAF)	구현 웹 애플리케이션 방화벽	nginx 연동 WAF, 악성 요청 탐지/차단
IDS/IPS(Suricata)	구현 WAN Divert 모드(포트 8000)로 실시간 트래픽 검사, 커스텀 탐지를 9종(SQL Injection 4종·XSS 4종·테스트 1종) 적용	WAN 인바운드 방화벽 규칙에서 divert-to 로 Suricata에 패킷 전달 → 커스텀 룰 매칭 시 alert 로그 생성. 룰 파일 줄바꿈 누락으로 전체 룰셋 파싱 실패 상태였던 것을 발견·수정, 실제 alert 발생까지 검증 완료

4

보안정책

4.1. 접근 제어 정책

4.1.1. 방화벽 규칙

설계(미적용) 아래 규칙은 설계 완료 상태이며, 실제 OPNsense에는 아직 적용되지 않음(팀 확인 후 진행 예정).

[표 14] 외부 → DMZ (웹 서버) 규칙

출발지	목적지	포트	허용/차단	사유
any	웹서버	443/tcp	허용	HTTPS 서비스 제공
any	웹서버	80/tcp	허용	HTTP → HTTPS 리다이렉트
any	웹서버	그 외 전체	차단	불필요한 노출 최소화

[표 15] DMZ → 내부망 규칙

출발지	목적지	포트	허용/차단	사유
웹서버	DB서버	3306/tcp	허용	애플리케이션 DB 조회·기록
웹서버	Graylog	1514, 5044/tcp	허용	로그 전송

[표 16] 관리망 → 모든 서버 규칙

출발지	목적지	포트	허용/차단	사유
관리자 VPN IP	전체 서버	22/tcp	허용	SSH 관리 (특정 IP 제한, VPN 경유만 허용)

[표 17] 내부망 서버 → 내부망 서버 규칙

출발지	목적지	포트	허용/차단	사유
KIS 연동서버(10.10.10.4)	DB서버	3306/tcp	허용	시세 데이터 적재
카카오 로그인 연동서버(10.10.10.6)	DB서버	3306/tcp	허용	소셜 로그인 계정 동기화
구현 구글 로그인 연동서버(10.10.10.8)	DB서버	3306/tcp	허용	소셜 로그인 계정 조회·생성(UFW로 직접 허용 추가)
구현 뉴스 연동서버(10.10.10.7)	DB서버	3306/tcp	허용	네이버 뉴스 적재(UFW로 직접 허용 추가)

[표 18] 내부망 → 외부망

출발지	목적지	포트	허용/차단	사유
EST 서버(10.10.10.4)	KIS API 서버	개미집 인프라 구축 보고서 인프라 보안 129443디언즈 31000/tcp	허용	시세 API 호출 EST

출발지	목적지	포트	허용/차단	사유
카카오 로그인 연동서버(10.10.10.6)	kauth.kakao.com, kapi.kakao.com	443/tcp	허용	소셜 로그인 API 호출
구현 구글 로그인 연동서버(10.10.10.8)	oauth2.googleapis.com, www.googleapis.com	443/tcp	허용	구글 OAuth 토큰 교환 · 프로필 조회
구현 웹서버 (10.10.10.3)	accounts.google.com	443/tcp	허용	구글 로그인 인증화면 리다이렉트(브라우저 경유이나 로그인 초기화 요청 자체는 웹서버가 생성)
구현 웹서버 (10.10.10.3)	news.google.com	443/tcp	허용	구글 뉴스 RSS 수집(비공식 공개 엔드포인트, 인증 불필요)
구현 뉴스 연동서버(10.10.10.7)	naverapihub.apigw.ntruss.com	443/tcp	허용	네이버 뉴스 검색 API 호출(NCP API Hub, X-NCP-APIGW-API-KEY 인증)

4.1.2. IP 접근 제어

[표 19] 화이트리스트 (허용 목록)

구분	수치
TBD	실제 허용 IP 목록

[표 20] 블랙리스트 (차단 목록)

구분	수치
TBD	실제 차단 IP 목록 (예: 로그인 실패 다수 IP 자동/수동 차단 기준)

4.2. 로그인 및 권한 정책

4.2.1. 사용자 비밀번호 정책

해당 없음(2026-08-12부터) — 로그인을 카카오 소셜 전용으로 전환하면서 자체 아이디·비밀번호 회원가입/로그인을 폐지함. 아래는 폐지 전 정책 기록(코드는 남아있으나 register.php/login.php가 더 이상 호출하지 않는 미사용 상태).

[표 21] 사용자 비밀번호 정책 (사용 중단)

구분	항목	수치
아이디	형식	설정확인(미사용) 영문·숫자·언더스코어 3~50자 ($^{\wedge}[A-Za-z0-9_]{3,50}\$$)
비밀번호	길이·구성 규칙	TBD 실제 정규식 재확인 필요(미사용 상태)

4.2.2. 로그인 보안

브루트포스 잠금(login_attempts)은 자체 로그인 페이지로 현재 미사용. CSRF는 매수/매도 등 다른 상태 변경 엔드포인트에서 여전히 활성화 사용 중.

EST 로그인 정책 개미집 인프라 구축 보고서 인프라 보안 12기 가디언즈 EST		
구분	항목	수치

구분	항목	수치
계정 잠금	실패 임계치	설정확인(미사용) 사용자 기준 5회 / 15분 — 과거 실측 검증(6번째 시도 정확히 차단) 완료, 현재는 로그인 자체가 카카오 전용이라 호출되지 않음
IP 잠금	실패 임계치	설정확인(미사용) IP 기준 20회 / 15분
요청 위조 방지	CSRF 토큰 검증	구현 세션 기반 토큰, hash_equals 비교 — 매수/매도 등 다른 폼에서 계속 사용 중, 위조 요청 차단 실측 완료

4.2.3. 관리자 계정 보안 (SSH)

[표 23] SSH 관리자 계정 보안 정책

구분	항목	적용 정책
접근 경로	VPN 경유만 허용	구현 WireGuard 메시 내부에서만 SSH 접근 가능
인증 방식	키 기반 여부	TBD 비밀번호 인증 비활성화·공개키 전용 전환 여부 확인 필요
Root 로그인	직접 로그인 차단	TBD
권한 상승	sudo 정책	설정확인 비밀번호 인증 필요 (NOPASSWD 미적용)

4.2.4. 관리자 페이지(백오피스) 관리자 계정 보안 정책

[표 24] 관리자 페이지(백오피스) 관리자 계정 보안 정책

구분	항목	적용 정책
TBD	별도 백오피스 존재 여부부터 확인	

4.2.5. 세션 관리 정책

구분	항목	적용 정책
쿠키 속성	HttpOnly / SameSite / Secure	구현 HttpOnly, SameSite=Lax, Secure(프록시 경유 시 X-Forwarded-Proto 기준 조건부 적용)
세션 파기	로그아웃 시 처리	구현 세션 즉시 파기
유효 타임아웃	자동 로그아웃 기준	TBD

4.2.6. 계정 관리 정책

구분	항목	적용 정책
계정 식별	가입 방식	구현 카카오·구글 소셜 로그인만 지원(2026-08-12부터). register.php는 아이디·비밀번호 회원가입을 폐지하고 login.php로 리다이렉트만 수행. users 테이블에 oauth_provider/oauth_id 컬럼 추가하여 제공자별 계정 식별(동일 이메일이면 기존 계정에 연동)
비밀번호	변경 기능	구현 mypage.php의 비밀번호 변경 기능 제거(로컬 비밀번호 자체가 없어서 죽은 기능이었음)

EST

개미집 인프라 구축 보고서
인프라 보안 12기 가디언즈

EST

구분	항목	적용 정책
휴면 계정	처리 기준	TBD
권한 변경	절차	TBD

4.2.7. 변경관리 정책

구현(프로세스) 방화벽 규칙 및 서버 설정 변경 시, 설계안을 먼저 공유·검토받은 뒤 적용하며 임의 즉시 적용을 지양함. 본 프로젝트의 방화벽 정책 설계~적용 프로세스 자체가 실제 적용 사례임(설계 후 팀 확인 → 승인 시 적용). 단, 이는 기술적 통제가 아닌 팀 운영 절차임에 유의.

4.2.8. 취약점 점검 주기 정책

TBD 정기 점검 체크리스트(4.5.4)와 별개로, 코드·인프라 취약점 점검 주기 합의 필요. 참고: 본 프로젝트에서 1회 전체 보안 감사 수행(CSRF, 세션, 브루트포스, SQLi, 레이스컨디션, CSV 인젝션 등 점검·조치·검증 완료).

4.2.9. 개인정보 처리 및 파기 정책

TBD 회원 정보(아이디, 거래내역) 보유기간 및 탈퇴 시 파기 기준 — 팀 합의 필요.

4.2.10. DB 접근 권한

[표 25] DB 접근 정책

계정 종류	권한	용도
webapp	설정확인 특정 호스트(10.10.10.%) 한정, DML 권한	애플리케이션 서버 접속용
TBD		관리자 계정

4.3. 데이터 보호 정책

4.3.1. HTTPS 적용

[표 27] HTTPS 적용 정책

구분	수치
적용 범위	구현 전체 트래픽 HTTPS 강제
보안 헤더	구현 HSTS 등 add_header 적용, server_tokens off
TLS 버전	TBD TLS 1.0/1.1 비활성화 여부 확인 필요

4.3.2. 크롤링/수집 데이터 보호

구현(범위 조정) 별도 크롤링 서버는 웹서버 외에 뉴스 연동서버(10.10.10.7) 1대 추가 운영. 웹서버(10.10.10.3)의 cron 스크립트는 구글 뉴스 RSS·시세 데이터를 수집·저장하고, 뉴스 연동서버는 네이버 뉴스 검색 API를 수집·DB에 직접 저장. 웹서버 스크립트는 외부에서 직접 호출되지 않도록 nginx location 규칙으로 차단됨.

EST

스 원문 링크 저장을 위해 market_news.url에 원문 링크를 저장하고, 뉴스 리다이렉트 URL이 500자를 초과할 경우 VARCHAR(500)에서 확장. 화면에서는 URL이 있을 때만 클릭 가능한 링크로 표시.

EST

TBD 네이버 뉴스 검색 API(openapi.naver.com) 연동 준비 중 — Client ID/Secret 발급 대기, 종목코드 자동 매칭(제목·본문에서 회사명 추출 → symbol_names 대조) 로직 별도 구현 필요. "별도 API 서버"로 이 수집을 처리할지, 웹서버에서 직접 호출할지는 미정 — 확정되면 3.1의 서버 구성표 및 3.2의 네트워크 구역에도 반영 필요.

4.3.3. DB 암호화

[표 29] DB 암호화 정책

수치
TBD 현재 저장 데이터 암호화 미적용으로 파악, 적용 여부 팀 결정 필요

4.4. 보안 관리 정책

4.4.1. 보안 업데이트

TBD OS·패키지 정기 업데이트 정책(주기, 긴급패치 적용 기한)

4.4.2. 백업

TBD 백업 대상·방식

4.4.3. 백업 주기

TBD

4.4.4. 백업 확인

[표 33] 백업 확인 체크리스트

구분	백업 대상	백업 및 확인 주기	점검 및 테스트 내용
TBD			

4.5. 로그 기록 및 보관 정책

4.5.1. 로그 기록 대상

[표 34] 로그 기록 대상

구분	수치
웹서버 로그	구현 nginx access/error, ModSecurity audit log
애플리케이션 로그	구현 update_*.log, match_orders.log, ws_listener.log, php8.5-fpm.log (전수 Graylog 연동, harvester 로그로 검증 완료)
IDS(Suricata) 로그	구현 OPNsense syslog(UDP 1514)로 Graylog에 실시간 전달 확인
방화벽(filterlog) 로그	TBD OPNsense syslog 프로그램 목록에서 filterlog / firewall 항목이 비활성 상태로 확인됨 — Graylog로 방화벽 허용/차단 로그는 미전달 중. 필요 시 추가 활성화 가능

4.5.3. 로그 점검

TBD

4.5.4. 정기 점검

[표 37] 정기 점검 체크리스트

구분	수치
TBD	

4.6. 서버 내부 보안 강화

이하 항목은 리눅스 서버 자체의 하드닝 설정입니다. 개미집 서버(Ubuntu + nginx + PHP-FPM + MariaDB)에는 아직 별도로 점검·적용되지 않은 상태이며, 명령어는 **부록(7장)**의 점검표와 동일합니다.

4.6.1. 파일 시스템 보안

항목	목적	상태
/etc/shadow, /etc/passwd 권한	계정 정보 보호	TBD
/tmp noexec,nosuid,nodev 마운트	임시 디렉터리 통한 악성코드 실행 차단	TBD
SUID/SGID 파일 점검	권한 상승 취약점 탐지	TBD
umask 027	신규 파일 기본 권한 최소화	TBD

4.6.2. 커널 및 네트워크 보안 (sysctl)

설정 항목	권장 값	목적	상태
net.ipv4.tcp_syncookies	1	SYN Flood 방어	TBD
net.ipv4.conf.all.accept_redirects	0	ICMP Redirect 공격 차단	TBD
net.ipv4.ip_forward	0	서버 라우터화 방지	TBD
net.ipv4.conf.all.rp_filter	1	IP Spoofing 방어	TBD
kernel.randomize_va_space	2	ASLR 활성화	TBD
fs.suid_dumpable	0	Core Dump를 통한 민감정보 유출 방지	TBD

4.6.3. 접근/무결성 도구

도구	목적	상태
AppArmor	프로세스별 접근 자원 제한(강제 접근 통제)	TBD
auditd	계정/인증 파일 변경, sudo 사용 감사 로그	TBD
AIDE	시스템 파일 무결성(해시) 검증	TBD
EST	개미집 인프라 구축 보고서	EST
send-only(chattr +a)	침해인 후로 보안책 관조 탕연즈	TBD

도구	목적	상태
GRUB 부트로더 암호	단일 사용자 모드 악용 방지	TBD

5 인프라 구축 결과

5.1. 인프라 구축 정보

5.1.1. 서버별 정보

TBD 서버 이름 / 외부IP / 내부IP / VPN IP / USER ACCOUNT / 담당자 — 최종본에만 채우고 공유 범위 주의 (민감정보)

5.1.2. 포트 포워딩

TBD

5.2. 상세 정보

TBD 서버 구축 사진(각 서버에서 `uname -a`, `hostnamectl`, `ip a`, `w` 실행 캡처) 필요: 웹서버(NGINX) / DB서버 (MariaDB) / OPNsense / 카카오 연동서버 / KIS 연동서버 / Graylog서버

해당없음 크롤링 · AI · 백업 · OPNsense-2 항목은 삭제

5.3. 접속 테스트 및 차단 테스트(룰셋 테스트)

TBD 방화벽 적용(4.1.1) 이후 실제 테스트하여 차단 로그·터미널 캡처 필요

- 외부망 → 각 서버(웹서버 / DB서버 / 카카오연동서버 / KIS연동서버 / Graylog서버) 차단 테스트 (ping/nmap)
- 각 서버 SSH 로그인 5회 실패 시 IP 차단 테스트 (fail2ban 등 도입 여부에 따라 다름)
- 비정상 로그인 탐지(무차별 공격) IDS/IPS 탐지 테스트

참고: 로그인 실패 잠금은 웹 애플리케이션 레벨(login_attempts 테이블)로 이미 구현·테스트 완료(6번째 시도에서 정확히 차단 확인) — **구현** . 서버 SSH 레벨의 5회 실패 차단(fail2ban 등)은 별도 확인 필요 — **TBD** .
크롤링 · AI · 백업 서버 관련 테스트 항목은 **해당 없음**이므로 삭제.

EST

EST

6

실제 공격 시뮬레이션 및 방어 검증

범용 OWASP 체크리스트가 아니라, 개미집이 실제로 가진 기능(매수/매도, 세션, 회원가입, 거래내역 내보내기 등)을 겨냥한 공격 위주로 구성했습니다. 이 장의 모든 항목은 실제 개미집 서버에서 직접 공격을 재현하고 결과를 캡처해야 하는 증적 섹션이며, 아래 표는 방법과 기대 결과의 틀만 제공합니다.

6.1. CSRF(요청 위조) 공격 — 매수/매도 주문 위조

항목	내용
공격 시나리오	공격자가 만든 외부 페이지에서 피해자 세션으로 <code>buy.php</code> / <code>sell.php</code> 에 임의 주문을 위조 전송
방어 계층	구현 세션 기반 CSRF 토큰(<code>hash_equals</code> 비교)을 <code>buy/sell/cancel_order/modify_order</code> 등 상태 변경 엔드포인트 전체에 적용
테스트 방법	CSRF 토큰 없이(또는 잘못된 토큰으로) <code>buy.php</code> 에 직접 POST 요청 전송
결과	구현 세션 기간 중 위조 요청 거부 실측 완료(과거 세션 검증) — 최종 보고서에는 재현 스크린샷 첨부 권장 TBD

6.2. 로그인/회원가입 무차별 대입 공격 (Brute Force)

항목	내용
방어 계층	구현 애플리케이션 레벨 계정 5회/15분, IP 20회/15분 잠금(<code>login_attempts</code> 테이블), 회원가입 5회/시간/IP(<code>registration_attempts</code> 테이블)
테스트 방법	동일 계정에 잘못된 비밀번호로 연속 로그인 시도
결과	구현 6번째 시도에서 정확히 차단 확인(과거 세션에서 실측 완료)
SSH 레벨(서버)	TBD fail2ban 등 서버 SSH 브루트포스 방어는 별도 미도입 — 부록 7.1 참고

6.3. 매수/매도 동시 요청 레이스컨디션 (계좌 초과 매도)

항목	내용
공격 시나리오	동일 종목 보유수량을 초과해서 매도 주문 2건을 동시에(Race) 전송 — 락 없이 처리 시 실제 보유량보다 많은 수량이 체결되어 서비스 자산이 음수가 될 수 있음
방어 계층	구현 <code>sell.php</code> 의 포트폴리오 조회를 <code>SELECT ... FOR UPDATE</code> 행 잠금으로 전환하여 동시 요청 간 잔여 수량을 직렬화
테스트 방법	동일 계정으로 같은 종목 매도 요청 2개를 동시에(예: <code>curl</code> 백그라운드 병렬 실행) 전송 후 최종 보유수량이 음수가 되지 않는지 확인
결과	TBD 최종 보고서에는 동시 요청 재현 스크립트 + 체결 후 잔고 조회 결과 첨부

항목	내용
공격 시나리오	본인 세션으로 로그인한 상태에서 주문 취소(<code>cancel_order.php</code>), 메모 수정(<code>update_trade_memo.php</code>) 등에 타인의 주문/거래 ID를 파라미터로 전달
방어 계층	TBD 각 엔드포인트에서 대상 레코드의 소유자(<code>user_id</code>)와 세션 사용자 일치 여부를 매번 검증하는지 코드 재확인 필요
테스트 방법	계정 A로 로그인 후, 계정 B 소유의 <code>order_id/trade_id</code> 를 취소·수정 요청에 삽입
결과	TBD

6.5. CSV/수식 인젝션 (거래내역 내보내기)

항목	내용
공격 시나리오	거래 메모에 <code>=1+1</code> , <code>=HYPERLINK(...)</code> 등 수식을 입력한 뒤, 다른 사용자(관리자 포함)가 <code>history_export.php</code> 로 거래내역을 CSV로 내보내 엑셀에서 열 때 수식이 실행되는 공격
방어 계층	구현 <code>csvSafe()</code> 헬퍼로 <code>=+-@</code> 로 시작하는 값 앞에 작은따옴표를 강제 삽입(메모 필드 적용)
테스트 방법	메모에 <code>=1+1</code> 입력 후 거래내역 CSV 내보내기 → 엑셀에서 열어 수식이 아닌 텍스트로 표시되는지 확인
결과	구현 방어 코드 적용 완료 — 재현 캡처 TBD

6.6. SQL Injection

항목	내용
공격 대상	<code>stock.php</code> 의 <code>symbol</code> 파라미터 등 사용자 입력이 쿼리에 반영되는 지점(로그인은 카카오 전용 전환으로 아이디/비밀번호 입력 필드 자체가 없어짐)
방어 계층	구현 전체 쿼리 PDO Prepared Statement 적용(전수 코드 검토 완료), 사용자 입력이 SQL 문자열에 직접 연결되는 지점 없음
테스트 방법	<code>curl -s -o /dev/null -w "%{http_code}" "https://junwon.xyz/stock.php?symbol=1' OR 1=1--"</code>
결과	TBD 200/오류 응답 여부와 실제 DB 영향 없음을 캡처로 확인

6.7. 스트림(/stream) 미인증 접근 시도

항목	내용
공격 시나리오	로그인하지 않은 상태에서 실시간 시세 SSE 엔드포인트(<code>/stream</code>)에 직접 접근하여 무료로 실시간 데이터를 취득 시도
방어 계층	구현 <code>nginx_auth_request</code> + <code>_auth_check.php</code> 로 세션 인증된 사용자만 통과
테스트 방법	로그아웃 상태에서 <code>curl -i https://junwon.xyz/stream</code>
결과	구현 미인증 401, 인증 200 실측 완료(과거 세션 검증) — 최종 캡처 TBD

항목	내용
공격 시나리오	배포 중 남은 .bak / .env / .sql 등 백업·설정 파일이나 cron 전용 스크립트 (update_investor_ranking.php 등)를 URL로 직접 호출
방어 계층	구현 nginx에서 확장자 기반 차단(W.(bak old orig save swp sql sh md log env)) 및 cron 전용 스크립트 명시적 URL 차단 규칙 적용
테스트 방법	<code>curl -I https://junwon.xyz/config/db.php.bak</code> , <code>curl -I https://junwon.xyz/update_investor_ranking.php</code>
결과	TBD 403/404 확인 캡처 필요

6.9. VPN 우회 관리 접근 시도

항목	내용
방어 계층	구현 SSH-서버 관리 접근은 WireGuard VPN 내부에서만 허용, 외부 공인망에서는 직접 접근 불가
테스트 방법	VPN 연결 해제 후 각 서버 22번 포트로 직접 접속 시도
결과	TBD 타임아웃/연결거부 캡처 필요

7부록 — 서버별 내부 보안 정책 점검표

KISA 주요정보통신기반시설 기술적 취약점 분석·평가 방법(2021.3) 기반. 적용 대상: 웹서버 / DB서버 / 카카오 연동서버 / KIS 연동서버 / Graylog 서버 (Ubuntu 24.04 계열). OPNsense는 별도 FreeBSD 체계로 항목 일부만 적용.

아래는 공통 점검 항목입니다. 서버마다 실제 점검 결과(PASS/FAIL)는 팀이 직접 실행 후 채워야 합니다.

7.1. 계정 및 SSH 통제

점검 항목	점검 명령어	양호 기준
root SSH 직접 접속 차단	grep "^PermitRootLogin" /etc/ssh/sshd_config	PermitRootLogin no
패스워드 인증 비활성화	grep "^PasswordAuthentication" /etc/ssh/sshd_config	PasswordAuthentication no
공개키 인증 활성화	grep "^PubkeyAuthentication" /etc/ssh/sshd_config	PubkeyAuthentication yes
로그인 시도 제한	grep "MaxAuthTries" /etc/ssh/sshd_config	5 이하
세션 타임아웃	grep TMOUT /etc/profile	TMOUT=300 이하

7.2. 계정/패스워드 정책

점검 항목	점검 명령어	양호 기준
패스워드 최대 사용기간	grep PASS_MAX_DAYS /etc/login.defs	90일 이하
로그인 실패 잠금	cat /etc/security/faillock.conf	deny=5, unlock_time=600
불필요/퇴직자 계정 정리	awk -F: '\$3>=1000{print \$1}' /etc/passwd	사용 계정만 존재

7.3. 파일 시스템 보안

점검 항목	점검 명령어	양호 기준
/etc/shadow 권한	stat -c '%a %n' /etc/shadow	600
World-Writable 파일	find / -xdev -perm -0002 -type f 2>/dev/null	없음
/tmp 보안 마운트	mount grep /tmp	noexec,nosuid,nodev
SUID/SGID 파일	find / -perm -4000 -o -perm -2000 2>/dev/null	기준선 대비 추가 없음

7.4. 커널/네트워크 보안 (sysctl)

설정 항목	권장 값	확인 명령어
net.ipv4.tcp_syncookies	1	sysctl <항목명>
net.ipv4.conf.all.accept_redirects	0	
net.ipv4.ip_forward	0	
net.ipv4.conf.all.rp_filter	1	
net.ipv4.conf.all.accept_source_route	0	
kernel.randomize_va_space	2	

7.5. 로그 무결성 및 관리

점검 항목	점검 명령어	양호 기준
로그 보존 기간	grep -E "^rotate ^compress" /etc/logrotate.conf	90일(13주) 이상
auth.log 변조 방지	lsattr /var/log/auth.log	append-only(a) 속성
auditd 활성화	systemctl is-active auditd	active
AIDE 파일 무결성 DB	ls -l /var/lib/aide/aide.db	기준 DB 존재

7.6. 정기 점검 주기(권장)

주기	점검 내용
일일	서비스 정상 동작, 로그인 실패/에러 로그 확인, 방화벽 상태 확인
주간	sudoers 정책 검증, 방화벽 정책 검토, 서버 리소스 사용률, 계정 권한 확인
월간	OS 보안 패치 적용, 불필요 계정 정리, 백업 복구 테스트, 보안 스캔
분기	IDS/IPS 룰셋 업데이트, 방화벽 정책 전체 재검토, 취약점 스캐닝

TBD 위 주기는 예시이며, 팀 합의로 확정 후 4.5.4/4.4.4 표와 일치시킬 것.